

ROHITH DONTHULA

OFFENSIVE SECURITY · DETECTION ENGINEERING · CLOUD & AI SECURITY

New York City, NY | (551) 325-9945 | donthula.rohith22@gmail.com | rohithdonthula.com | linkedin.com/in/rohith-donthula | github.com/Donthularohith

PROFESSIONAL SUMMARY

Security engineer who works all three sides of the problem: breaking systems, building the detections that catch the break, and shipping the product that does both. 3+ years spanning network and web/API penetration testing on enterprise banking infrastructure (Capgemini), purple-team detection engineering under HIPAA (Cerner), and MSSP SOC operations under PCI DSS (SecVal). Co-founder of **Zhask**, where I architected **kaveo** — an AI-native, self-hosted cloud security platform with 96 deterministic detectors, 43 read-only AWS collectors, and a grounded-AI layer that drops any claim it cannot cite. MS Cybersecurity (Yeshiva University); CompTIA PenTest+, CySA+, Security+.

SKILLS

Offensive Security: Network and web/API penetration testing, adversary emulation (Atomic Red Team, Caldera, Cobalt Strike), Burp Suite, Metasploit, Nmap, BloodHound, Impacket, Responder, OWASP Top 10 & API Top 10, AD attack paths (Kerberoasting, PtH/PtT, lateral movement)

Detection & Response: Splunk SPL, Sigma, ELK, Stellar Cyber Open XDR, CrowdStrike Falcon EDR, Snort/Suricata, Cortex XSOAR (SOAR automation), threat hunting, IR playbooks (NIST 800-61), forensics (EnCase, FTK, Volatility)

Cloud Security: AWS IAM graph & privilege-escalation analysis, CSPM engineering, Pacu, ScoutSuite, Prowler, Azure Security Center, Zero Trust / ZTNA, NGFW (Palo Alto), IBM QRadar

AI Security: Grounded/cited AI architecture, OWASP LLM Top 10 threat modeling (prompt injection, agent tool-use, output exfiltration), MITRE ATLAS mapping, LLM-assisted triage & enrichment, Model Context Protocol (MCP)

Identity & Data: Okta SSO/MFA, SailPoint, CyberArk, RBAC, DLP (Forcepoint), email security (Proofpoint), Tenable.io / Nessus / OpenVAS

Compliance: HIPAA, PCI-DSS, GDPR, SOC 2, NIST, CIS · **Code:** Python, PowerShell, Bash

EXPERIENCE

Co-Founder & Security Engineer

2025 – Present

Zhask — kaveo · New York City, NY

- Co-founded Zhask and architected kaveo, an AI-native self-hosted cloud security platform built on the thesis that determinism finds the truth and AI has to show its work.
- Designed and shipped the detection engine: 96 deterministic detectors and 43 read-only AWS collectors covering exposure, identity, data, logging, network, and secrets across the IAM/reachability graph — with zero AI agents on the trust-critical detection path.
- Built the grounded-AI layer where every model claim is a (text, citation) pair validated against an immutable evidence ledger; uncited or misciting claims are dropped before storage, enforced in the data model rather than the prompt.
- Closed the remediation loop end to end — prioritize by real blast radius, apply the fix through a scoped write role, re-scan to prove the finding no longer fires, then watch for drift and regression.
- Shipped a native MCP server for read-only, cited agent access; supported 7 interchangeable AI providers with zero-network mode by default. 30+ product surfaces, 300+ automated tests.

Security Operations Center Analyst

Apr 2026 – Present

Security Validation (SecVal MSSP) — New Jersey, US

- Monitor, triage, and respond to security events across multi-client environments using Stellar Cyber Open XDR and CrowdStrike Falcon; correlate IOCs and TTPs against MITRE ATT&CK.
- Run controlled adversary emulation — credential dumping, lateral movement, and persistence chains — to validate whether detections actually fire, then tune the rules that miss.
- Reconstructed a credential-theft intrusion from EDR and XDR telemetry, mapping observed activity to the same techniques emulated in purple-team work; findings fed detection engineering.
- Support PCI DSS compliance monitoring for hospitality clients and deliver vulnerability findings with actionable remediation guidance.

Cyber Security Analyst — Purple Team

Jun 2025 – Mar 2026

Cerner Healthcare — United States

- Ran purple-team operations across Cerner EHR environments — emulated adversary TTPs and hardened detections in the same sprint, fully aligned with HIPAA.
- Improved MTTD ~30% by building automated detections tuned to healthcare-specific threats; centralized log aggregation across clinical apps, cloud, and IAM.
- Drove continuous vulnerability management with Tenable.io, prioritizing by CVSS and clinical risk; tuned email security and DLP to stop phishing/BEC and PHI exfiltration.

Cyber Security Engineer

Jun 2021 – Jul 2024

Capgemini — India

- Performed network and web/API penetration testing against enterprise banking platforms with Burp Suite, Metasploit, and OWASP methodology — manually validating exploitability before rating or remediation, cutting high-risk exposures 18% by discarding unexploitable scanner noise.
- Demonstrated an AWS IAM privilege-escalation path from a low-privilege identity to administrative control in a controlled attack rather than flagging the permission — reduced privilege-escalation risk 35%.
- Validated Palo Alto firewall policy empirically through controlled attack simulation, iterating variants to isolate where policy actually leaked — 45% reduction in unauthorized access attempts.
- Ran coordinated red/blue exercises that improved incident-response time 28%; segmented SWIFT and payment networks (NGFW, IDS/IPS, RBAC, MFA) and passed PCI-DSS/GDPR audits with zero major findings.
- Improved forensic turnaround ~75% with EnCase and FTK, delivering litigation-ready reports for legal and compliance stakeholders.

SELECTED PROJECTS & RESEARCH

- **kaveo (Zhask)** — flagship: self-hosted, zero-egress CSPM/CNAPP; deterministic detection with a cited-evidence AI layer and verified remediation loop.
- **CSPM Platform** — modular Python scanners (IAM, S3, EC2, Security Groups, Lambda, RDS) with honeypot and threat-intel enrichment; ~90% detection accuracy, 30–60s alerting, mapped to MITRE/CIS/HIPAA/SOC 2/PCI.
- **Zero Trust Electronic Voting System (ZTEV)** — research-grant-funded prototype: ZTNA with per-request re-auth, AES-256 ballot envelopes, blockchain audit log, Snort-monitored traffic.
- **Penetration Testing & Threat Intel Capstone (Team Lead)** — red-team engagement mapped to MITRE ATT&CK; 40-page report, 12 critical findings, remediation playbook adopted by the program.

EDUCATION

MS, Cybersecurity — Yeshiva University, Katz School

Aug 2024 – May 2026

Cybersecurity Program — IIIT Bangalore

2023 – 2024

B.Tech, Computer Science & Engineering — Malla Reddy Institute of Technology

2019 – 2023

CERTIFICATIONS & HONORS

CompTIA: PenTest+ (PT0-003) · CySA+ (CS0-003) · Security+ CE (SY0-701) · Stackable: CNSP, CNVP, CSAP

Google Cybersecurity Professional (Coursera)

Honors: 2nd place, ISACA × Yeshiva CTF · 1st place, ISACA phishing challenge · Research grant, Zero Trust E-Voting (ZTEV)

Verify credentials: credly.com/users/rohith-donthula